



长亭科技
CHAITIN

自动化渗透测试平台（无锋）

自动化渗透测试平台 (无锋)

自动化渗透测试平台 (无锋)

关于长亭科技

知攻善防·智能安全

长亭科技是国际顶尖的智能网络安全公司之一，其全球首创、具有自主知识产权的智能语义分析技术，大幅提升了网络安全未知威胁的发现能力。面向数字时代的新型安全风险，长亭科技秉持“知攻善防，智能安全”的理念，通过新一代智能安全产品防护体系和专业的安全测试及咨询服务，已为超过4000家客户提供了先进可靠的网络安全防护。

联系我们

电话：400-032-7707

官网：www.chaitin.cn

邮箱：info@chaitin.com

地址：北京市朝阳区天辰东路7号

国家会议中心北区6层

蓝军能力建设挑战与思路

在数字化浪潮的席卷下，网络安全的重要性愈发凸显，越来越多的企业开始组建蓝军。一方面，蓝军可以常态化检验企业自身的防护能力，为企业网络安全筑牢防线；另一方面，还能够对外输出安全服务，助力其他企业提升网络安全水平。然而，在蓝军建设进程中，企业在人才培养和工具能力建设方面往往面临诸多挑战。

在网络安全行业发展浪潮中，甲方企业与安全服务厂商在蓝军体系建设的征程里，普遍遭遇工具建设、人才储备等共性瓶颈与发展困境。长亭科技作为行业内颇具影响力的安全服务厂商，自2015年便成立了安全服务团队。经过多年的不懈努力，通过构建持续的人才培养体系和强大的工具能力，团队规模现已超过500人。每年，长亭为大量客户提供攻防演练、渗透测试等蓝军服务，在能力和业务方面均已跻身行业头部行列。以下表格详细对比了长亭在规模化蓝军建设过程中遇到的挑战及应对思路，为其他企业的蓝军建设提供参考借鉴。

长亭自身（安全服务厂商视角）			企业蓝军视角	
挑战		十人以内小规模蓝军能力可依赖超级明星，数百人、上千人规模化蓝军如何构建竞争力？	• 超级明星招聘难 • 新人（应届）旧人（转岗）培养难 • 开源工具效果差，自研工具成本高	
思路	人才培养	• 依托大量项目，以战养兵 • 研发课程体系、靶场环境，推动人员能力快速晋级	• 通过招聘体制创新，广揽英才 • 参与外部实战机会，以战养兵 • 保障蓝军技术人员工作时间占比 • 引入外部专业技术培训	
	工具建设	• 组建专职研发团队，持续研发迭代自动化渗透测试平台 • 构建标准化知识库（特征、漏洞、利用等），持续积累知识	• 引入外部专业工具能力，工具能力应持续迭代演进 • 自研或依托外部持续更新知识库（特征、漏洞、利用等）	

本文重点聚焦于无锋自动化渗透测试平台，该平台旨在为企业蓝军解决工具能力快速提升的难题。关于蓝军人才培养，可参考长亭的其他相关方案。

自动化渗透能力构建思路

基于上述背景，长亭科技持续探索和构建自动化渗透能力，主要遵循以下思路：

敏捷开发模式

网络攻防领域技术迭代迅速，新的思路和需求层出不穷。为了紧跟技术发展步伐，无锋平台采用敏捷开发模式，具备快速迭代和上线的能力，最快可实现按天发布，确保平台能够及时响应市场需求和技术变化。

云原生架构

攻防任务的工作量波动较大，在保障关键时期，需求尤为旺盛。无锋平台借助云原生架构，拥有资源快速扩容及切换的能力，例如节点扩容、IP 切换等，能够灵活应对不同规模的任务需求，确保平台的高效稳定运行。

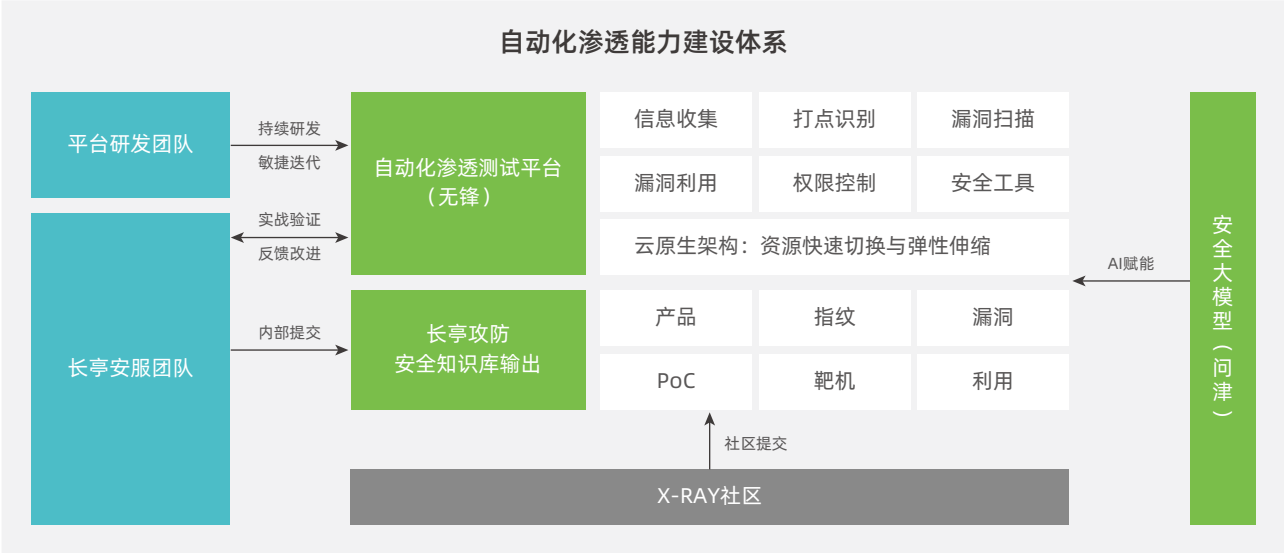
标准化知识库与运营体系

渗透测试的效果在很大程度上依赖于策略规则，如产品指纹、POC、EXP等。为此，长亭构建了标准化的知识库，为平台提供强大的知识支撑。同时，通过建立完善的运营机制，能够向内部蓝军团队和外部社区广泛收集知识，不断丰富和更新知识库内容。

“实战、反馈、改进” 闭环

不断在实战中大规模应用平台能力，并构建持续反馈、改进闭环体系，如收集漏误报数据、人工产出而非自动化产出成果，推动平台改进完成闭环，让平台实现能力“自生长”。

基于以上思路，长亭的自动化渗透能力建设体系如下图：



参照这些思路，企业蓝军在构建工具能力时，通常会面临自研资源不足、攻防知识库积累匮乏、实战场景单一等问题。为了解决这些痛点，长亭推出了无锋自动化渗透测试平台。

核心优势

多维度渗透能力

无锋平台具备全方位的渗透能力，涵盖信息收集、漏洞扫描、打点识别、漏洞利用、内网渗透以及丰富的安全工具等多个维度，为蓝军提供一站式的解决方案。

云原生架构

采用分布式可扩展的云原生架构，能够根据实际需求快速扩充和切换扫描资源，灵活应对不同规模的攻防任务，确保平台始终保持高效运行。

开箱即用

用户只需登录账号，即可获得长亭完整的自动化渗透能力，无需从头进行复杂的研发工作，大大降低使用门槛，提高工作效率。

高效更新

秉持敏捷迭代的理念，无锋平台以周为迭代单位，最快可实现天级更新，及时融入最新的技术和安全策略，始终保持平台的先进性和实用性。

产品+服务模式

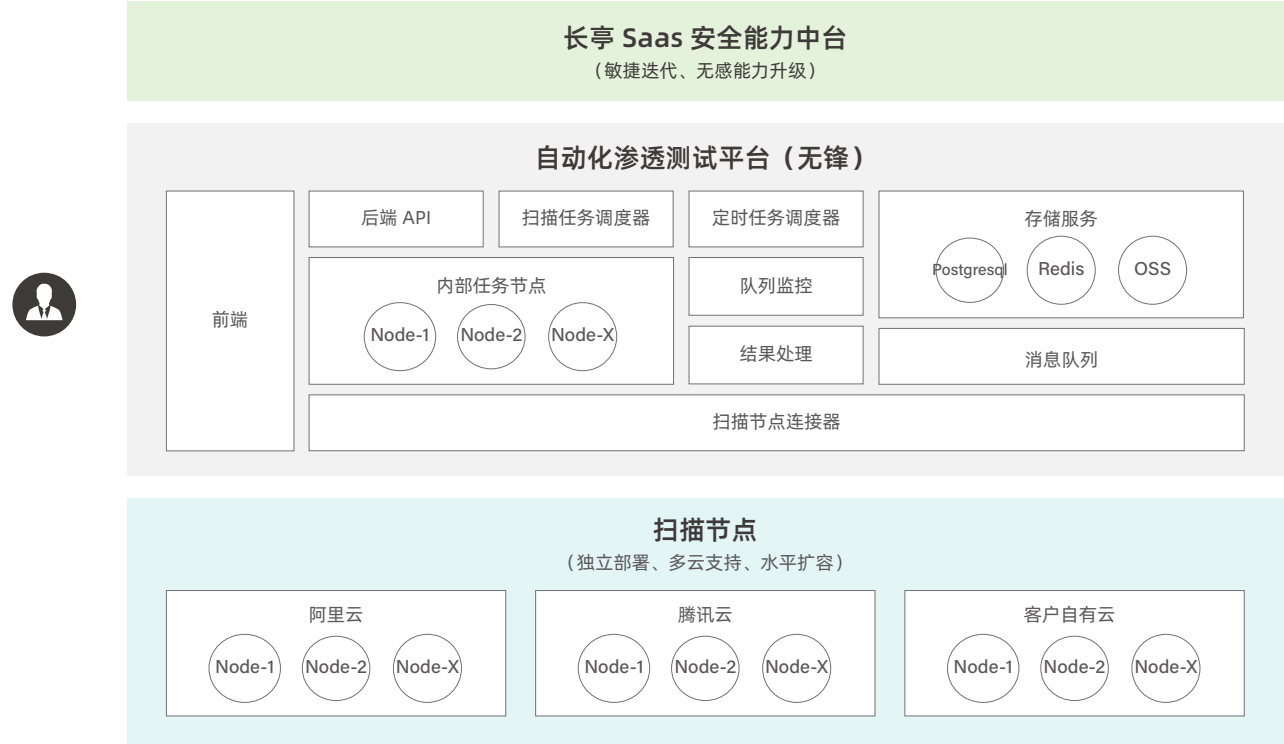
除了提供优质的产品，长亭还为用户提供便捷的沟通渠道，客户专属沟通群，产品专家能够快速解答用户在使用过程中遇到的疑问，并提供专业的实践指导，让用户更好地发挥平台的价值。

平台能力

整体介绍

无锋自动化渗透测试平台适用于蓝军对外部和内部进行攻防演练、渗透测试的场景，平台能力覆盖了信息收集、漏洞扫描、打点识别、漏洞利用等方面，同时对于渗透过程中蓝军人员可能遇到的其他场景需求，平台提供了多个安全工具。

无锋自动化渗透测试平台的架构如下图所示：



无锋自动化渗透测试平台的安全能力包含以下方面：

安全能力	概述	介绍
信息收集	自动化收集企业网络资产	关联资产、子域名收集、端口探测、协议识别、Web元信息爬取、应用指纹识别、目录（路径）收集、动态静态爬虫、资产血缘分析、资产打标与扩展元信息获取、资产降噪。
漏洞扫描	自动化发现目标资产漏洞	供应链漏洞扫描、DAST 漏洞扫描、被动漏洞扫描、弱口令漏洞扫描。
打点识别	自动化识别企业互联网突破口	重点关注产品分析、产品漏洞利用链检测。
漏洞利用	自动化利用漏洞获取权限	对打点识别模块检测到的利用链进行一键利用。
权限控制	Webshell管理	支持内部定制的连接方式，有效绕过 WAF 和流量检测，同时也兼容支持连接社区的冰蝎和哥斯拉等（目前仅支持 Java，后续会逐渐支持 .Net、PHP 平台）。
安全工具	蓝军常用工具	移动端资产提取、敏感信息收集、反连套件、域名/IP 信息查询、快捷指纹查询、全能编解码工具、Hash 反查、反弹 Shell 命令、通用密码查询、Java命令编码、杀软进程识别、邮箱收集等。

信息收集

无锋（X-Blade）自动化渗透测试平台通过综合运用备案资产发现、端口开放性扫描、指纹识别以及关联资产发现等技术，能够对目标网络进行全面而深入的信息收集。

- **关联资产：**支持通过备案信息查询、投资控股企业查询、空间测绘特征查询、SSL证书关联查询等方式查询本公司和关联公司的资产信息。
- **子域名收集：**通过长亭数据中台、子域名暴破、网页爬虫等多种方式收集企业子域名信息。
- **端口扫描：**可快速识别网络中开放的端口，进而对这些端口进行深入分析，以确定运行在其上的具体服务和应用。
- **WEB元信息获取：**支持收集十余种网页详情字段，除了URL、title、返回码等基础信息外，进一步收集静态&浏览器渲染响应，并针对蜜罐、登录入口、管理后台等进行特征打标。
- **应用指纹识别：**支持主动/被动指纹识别，支持识别产品&版本信息。
- **目录收集：**通过目录暴破、动静态爬虫等多种方式收集目录。
- **资产血缘分析：**支持查看资产发现逻辑和资产之间的关联关系，并支持可视化展示，支持资产聚合查询。
- **资产打标：**资产自动打标签，补充额外信息，包含登录页面、管理后台、蜜罐、CDN、云厂商归属等。
- **资产降噪：**自动过滤无效无意义结果，自动过滤域名泛解析结果、污染解析结果等。

信息收集	关联资产	子域名收集	端口扫描	WEB元信息	应用指纹识别	目录收集
	备案信息查询	长亭数据中台	多扫描引擎支持	十余种网页详情字段	主动指纹识别	目录暴破
	关联资产查询	子域名暴破	噪音IP自动识别与过滤	静态&浏览器渲染响应	被动指纹识别	动态爬虫
	空间测绘特征查询	网页爬虫	服务、产品、版本识别	特征打标	产品&版本识别	静态爬虫
	资产血缘分析	资产发现路径和关联关系：可视化展示 / 资产聚合				
	资产打标	自动打标签，补充额外信息：登录页面 / 管理后台 / 蜜罐 / CDN / WAF / 云厂商归属等				
	资产降噪	自动过滤无效无意义结果：域名泛解析 / 污染解析 / CDN等三方资产 / 防护设备误报 / 聚合过滤				

漏洞扫描

漏洞扫描技术，是一项专门设计用于识别和评估信息系统安全漏洞的功能。无锋通过引用长亭科技攻防知识库中的高质量漏洞检测插件和X-ray扫描引擎，对目标网络进行全面的探测和分析，以发现潜在的安全弱点。

- **供应链漏洞扫描：**依托内部攻防知识库的高质量原理插件，结合快速扫描模式，能够高效检测供应链漏洞。
- **弱口令专项扫描：**支持对 60 余种服务类和 50 余种 Web 应用类弱口令进行扫描，有效发现因弱口令导致的安全风险。
- **AI相关：**借助问津大模型的支持，自动研判可能出现的漏洞误报情况，提高漏洞扫描结果的准确性。
- **DAST+通用漏洞扫描：**可检测多种常见通用漏洞，如SQL注入；代码 / 命令注入；目录遍历、文件上传/下载/包含；敏感信息泄露等，全面排查目标网络的安全隐患。
- **漏扫配置：**支持通过复合条件筛选漏洞，提供多种扫描模式，并支持反连漏扫，满足不同场景下的扫描需求。

重点关注（打点识别）

打点识别是指从目标单位的海量资产信息中找到可以突破的边界入口点，是攻防演练活动中的核心步骤。通常蓝军人员会实施全量的漏洞扫描，从中去寻找可以实现远程代码执行的漏洞来进行边界突破。然而较多场景下，全量漏洞扫描的效果在防护策略严格的场景下效果会大打折扣，且大量攻击特征报文会引起防守侧关注，导致攻击失效。

为了缓解这一问题，无锋平台提供了重点关注（打点识别）功能，使得蓝军人员可以在尽可能少发送带有攻击特征的扫描报文、且发送少量报文前提下识别入口点。此外，因为该环节攻击特征非常弱，属于信息收集，还可以在攻防演练之前，就帮助攻击队识别入口信息，该功能主要分为两大模块：

- **利用检测：**该模块会在信息收集过程中采集重点产品的特征（如版本、响应、接口等信息），基于特征去识别对应的可利用漏洞。
- **重点关注产品/服务：**该模块会从平台已收集的资产中根据产品指纹特征匹配出常见可用于打点的资产，并为蓝军提供打点建议（建议利用漏洞等参考资料）。

该功能在信息收集后自动启用，无需开启漏扫，与快捷利用打通，方便用户进行后续利用。打点识别模块为长亭在业内的创新成果，在大量攻防演练中帮助攻击队提前识别了防守方入口，为快速得分打下了基础。

- **利用检测模块：**在信息收集进程中，该模块会精准采集重点产品的关键特征信息，涵盖版本号、响应信息、接口配置等核心维度。基于这些详细特征，能够高效识别出与之对应的可利用安全漏洞，为后续攻击行动提供重要依据。
- **重点关注模块：**此模块会从平台已完成收集的资产数据中，依据产品指纹特征进行深度匹配，筛选出常见且适合作为攻击切入点的资产目标。同时，为蓝军团队提供专业的打点策略建议，包括推荐可利用的漏洞类型及相关技术参考资料，助力攻击行动顺利开展。

这两大功能模块在信息收集完成后将自动激活运行，无需另行启动漏洞扫描程序。并且，该功能与快捷利用模块实现了无缝衔接，极大地方便了用户开展后续的漏洞利用操作。值得一提的是，打点识别模块是长亭科技在行业内的一项创新性成果。在众多实际攻防演练场景中，该模块成功帮助攻击队伍提前锁定防守方的薄弱入口，为快速突破防线、获取有效得分奠定了坚实基础。

漏洞利用

无锋支持自动化利用漏洞获取权限：

- **一键利用：**结合打点识别的利用检测结果，对漏洞进行一键化利用，快速获取目标权限，简化操作流程，提高攻击效率。
- **功能联动：**可与后渗透权限控制部分的功能实现联动，方便蓝军进行更深入的内网测试，进一步拓展攻击成果。
- **知识仓库：**依托由长亭数百位安全专家共同维护的标准化、结构化漏洞知识库，为漏洞利用提供强大的知识支持，确保利用的准确性和有效性。
- **运营体系：**建立了完整的闭环反馈机制，根据实战使用反馈，不断补充和优化规则库，使平台的漏洞利用能力持续提升。

权限控制

01/ webshell

长亭全自研webshell与快捷利用深度打通，可在注入内存马之后，建立与目标服务器的持久化连接通道，不仅支持对目标主机的深度信息探测，还能以此为支点，无缝衔接后续内网渗透工作。该模块集成了以下核心功能：

- **上线信息：**可全面获取目标操作系统的环境变量等基础信息，助您深入了解目标系统运行环境，为后续渗透操作提供有力依据。
- **文件管理：**支持对目标服务器文件系统进行全方位管理。您不仅能够查看文件系统架构，还可以轻松实现文件上传、下载，以及目录和文件的创建操作，满足多样化的文件交互需求。
- **命令执行：**在目标服务器上执行命令的过程中，团队成员可实时同步查看命令执行过程及结果，确保团队协作顺畅，有效提升渗透作业效率。
- **武器中心：**提供丰富的蓝军常用武器化插件，如内存马注入、代码执行等，为渗透作业提供强大的技术支持，助力您在复杂的网络环境中成功突破防线。
- **连接状态：**支持查看目标端口信息，方便您掌握目标服务器的网络连接状态，及时发现潜在的网络通信风险，为内网渗透和横向移动提供关键情报。
- **HTTP请求：**借助目标服务器，可轻松发送HTTP请求，拓展渗透测试的边界，挖掘更多潜在漏洞和攻击面。
- **进程列表：**能够清晰展示目标服务器的进程列表，同时具备杀软进程识别功能，帮助您快速定位并规避可能存在的安全防护进程，保障渗透行动顺利进行。

无锋webshell模块具有诸多优势，总结如下：

- **反馈迭代闭环：**基于内外部实战反馈，持续迭代优化，确保产品性能与技术能力始终贴合前沿需求。
- **完整攻击溯源：**具备全流程攻击历史回溯功能，可快速生成结构化、可视化的攻击轨迹，为安全报告撰写与项目汇报提供清晰详实的数据支撑。
- **强效免杀效果：**通过深度特征混淆技术，实现卓越的免杀效果，有效规避传统安全防护机制的检测与拦截。
- **协同高效管理：**支持团队成员实时在线协作，通过灵活便捷的权限配置体系，实现多角色、多场景的高效协同作业。
- **全栈适配能力：**全面兼容主流 WEB 中间件，尤其针对国产化中间件进行专项优化与适配。
- **可视化交互体验：**拥有可视化界面，交互设计细致友好，提升用户体验，降低操作门槛，提高工作效率。

02/ 隧道代理

隧道代理可以用于建立内网流量通路，方便内网渗透，横向移动，扩展成果，无锋提供了自研稳定代理服务，优势总结如下：

- **免杀性能强：**移除了流量特征，可实现大部分情况免杀。
- **全平台兼容覆盖：**支持所有的常见平台。
- **突破网络隔离限制：**在网络访问受限场景，支持通过代理上线。
- **高效团队协同：**与项目管理打通，便于团队成员实时协作。

安全工具

无锋平台还提供了数十种在蓝军项目实践中常用的安全工具，助力提升蓝军项目的工作效率：

- **信息收集类：**包含域名备案查询、APK 脱壳分析等工具。域名备案查询功能，用户只需输入根域名或企业主体，即可查询相关的备案域名信息，不仅支持查询本公司，还可查询全资子公司、分支机构的备案信息，同时支持查询微信小程序、公众号、微博、APP 等移动端资产。APK 脱壳分析是长亭全自研的工具，基于物理机真机脱壳技术，能够绕过加固防护，有效收集安卓 APK 的基础信息和敏感信息。
- **编解码类工具：**哈希反查明文、全能编解码工具、java命令编码等，哈希反查明文，支持用户输入哈希值，查询明文信息。

此外，无锋平台还提供了 DNS LOG，支持无回显反连验证，方便安全工程师手动挖掘漏洞；杀软进程识别工具则应用于后渗透场景。小工具下载处基于开源社区和长亭自研成果，为用户提供了十几种蓝军常用小工具。

蓝军安全工具，助力项目效率提升		
信息收集类	编解码类	其他安全工具
• 域名备案查询 • IP信息查询 • APK脱壳分析 • 快捷指纹查询 • 产品密码查询 • 邮箱收集	• 哈希反查明文 • 全能编解码工具 • JAVA命令编码 ...	• DNS Log • 杀软进程识别 • 反弹Shell命令 • 小工具下载（十余种工具下载） ...

功能亮点

01/ 项目管理

无锋平台支持项目制管理方式，以项目为维度对项目成员、扫描范围、资源权限进行统一管理。这便于项目成员分工协作，并共享扫描结果。同时，平台支持通过可视化流程图的方式展示任务执行步骤和进度，使项目进展一目了然，提高项目管理的效率和团队内透明度。

02/ 用户和权限控制

采用 RBAC（基于角色的访问控制）权限控制机制，可精确控制不同用户的访问功能和数据权限。平台内置了企业管理员、安全专家等不同角色，每个角色拥有相应的权限，确保系统的安全性和数据的保密性。

03/ 数据分析

- **数据打标：**支持对扫描结果中的漏洞进行打标，方便团队成员之间同步信息；同时支持对 IP、端口、WEB / 路径等结果进行自动打标，标记内容包括登录入口、管理后台、蜜罐、CDN、WAF、负载均衡等；还具备自动数据降噪功能，能够自动消除无价值结果的干扰，提高数据分析的准确性和效率。
- **结果处理：**支持对扫描结果进行排除和恢复操作；支持导出项目任务和任务结果；能够生成专业的扫描报告，为用户提供全面、详细的测试结果。
- **数据检索与聚合：**提供丰富灵活的数据检索功能，支持高级检索；支持数据聚合检索，方便用户从海量数据中快速获取所需信息；同时支持查看资产发现路径，帮助用户深入了解资产的来源和关系。

04/ 分布式可扩展架构

- 采用解耦化架构设计，扫描节点可独立部署，并支持多云环境，提高了平台的灵活性和适应性。
- 扫描节点理论上可“无限”水平扩容，能够快速提升扫描速度和效率，满足不同规模的扫描任务需求。
- 作为 SaaS 化服务，功能迭代和问题修复更加便捷快速，最快可实现天级更新，确保平台始终保持良好的运行状态和先进的功能特性。

产品价值

多年来，无锋自动化渗透测试平台的卓越效果，在国内各项攻防演练中得到了充分验证：

- 在国家级网络安全攻防演练的舞台上，连续三年蝉联攻击队实网攻击第一名，并连续两年荣膺攻击队总分第一名。值得关注的是，长亨蓝军团队成员人均得分效率达到行业平均水平的 4 至 5 倍，在高强度、高对抗的演练环境中，展现出强大的实战能力。
- 在“粤盾”杯网络安全攻防演练、“磐石行动”等区域及行业顶尖网络安全赛事中，长亨蓝军凭借精湛的攻防技术与高效协同作战能力，多次以绝对优势包揽赛事第一名。这一系列佳绩不仅彰显了团队卓越的实战水平，更从实践层面深度验证了无锋自动化渗透测试平台在复杂攻防场景下的可靠性与有效性。

无锋自动化渗透测试平台依托的标准化知识库，经过多年的实战积累、精心打磨，以及外部社区的贡献，已具备相当规模。目前，累计高质量产品指纹达 6000 +，PoC7000 +。漏洞数据库不仅涵盖全量国外的 CVE 漏洞，还积累了海量国内漏洞，其中包含大量长亨自主研究、积累的高价值漏洞。

长亨蓝军持续在实战中锤炼平台能力，目前在日常安全服务业务中已全程使用该平台。围绕自动化打点率和自动化漏洞发现率两大关键指标，开展常态化能力建设。目前，自动化打点率已接近70%，自动化漏洞发现率已超过40%，且仍在不断提升。

应用场景

网络攻防实战演练

在网络攻防实战演练场景中，无锋自动化渗透测试平台展现出了卓越的全流程覆盖能力。从前期的信息收集阶段开始，平台便能借助多种先进技术，精准地采集目标网络的各类资产信息，为后续的攻击行动提供全面的数据支撑。在漏洞扫描环节，它凭借强大的检测能力，能够高效发现目标资产存在的各种安全漏洞，不放过任何潜在风险。而打点识别功能更是其一大亮点，可精准定位企业互联网的突破口，帮助蓝军快速找到攻击切入点。

不仅如此，无锋平台还具备出色的后渗透场景能力，在成功突破目标防线后，能协助蓝军进一步深入内网，实现权限提升、敏感信息获取等操作，为蓝军在实战演练中取得优势提供了有力保障。因此，无锋无疑是蓝军参与攻防演练的不二之选。

渗透测试项目交付

对于渗透测试项目交付工作，无锋平台同样表现出色，其功能全面覆盖渗透测试的整个流程。在信息收集方面，平台展现出了无与伦比的全面性，能够收集到包括关联资产、子域名、端口信息、Web元信息等多维度的数据，为精准分析目标系统奠定坚实基础。强大的漏洞扫描功能支持多种类型的扫描任务，无论是供应链漏洞、DAST 漏洞，还是弱口令专项扫描，都能高效完成，确保对目标资产的安全状况进行全面评估。

值得一提的是，渗透测试的成效高度依赖于策略规则，如产品指纹识别、漏洞POC以及漏洞利用方式等。无锋平台依托标准化知识库，为渗透测试提供了强大的赋能支持。通过建立面向内部安全服务专家和外部社区的知识收集运营机制，无锋平台构建了一个“实战、反馈、优化”的闭环流程。在实际应用中，根据实战经验反馈，不断对策略规则进行优化和完善，持续提升规则的丰富度和质量，从而保障渗透测试项目交付的高质量和高可靠性。

联系我们

电话：400-032-7707

官网：www.chaitin.cn

邮箱：info@chaitin.com

地址：北京市朝阳区天辰东路7号国家会议中心北区6层